

Incident Response Report

Rhetorical Hospital Security Division

Date: [Current Date]
Analyst: [Your Name]
ID: IR-2023-084

Executive Summary: A suspicious USB flash drive bearing the hospital's logo was discovered abandoned in the employee parking lot. To safely investigate its contents and prevent potential malware infection on the production network, the device was connected to an isolated virtualization workstation (sandbox). This report details the findings and provides risk mitigation recommendations.

Contents Discovered	The files stored on the external USB drive contain highly sensitive Personally Identifiable Information (PII) and corporate data. Recovered items include an employment application, an employee budget file, an employee resume, and personal family photographs. Finding: Storing confidential hospital work files alongside personal files on an unencrypted, removable drive is a severe violation of data handling best practices and poses a significant data leakage risk.
Attacker Mindset & Threat Vectors	The information contained in these files provides a lucrative reconnaissance opportunity for threat actors. Targeted Phishing: Family photos and resumes can be leveraged to craft highly convincing spear-phishing emails aimed at the drive's owner or their relatives. Social Engineering: Attackers can impersonate the drive owner using their personal data to trick colleagues into transferring funds or revealing credentials. Corporate Espionage: The employee budget file and job applications offer internal intelligence. Attackers could use this data to impersonate hospital executives or access deeper business systems.
Risk Analysis & Security Controls	This incident is a classic example of a USB Baiting Attack. Left-behind USBs are often loaded with malware (e.g., ransomware, keyloggers) designed to execute automatically when plugged in. To mitigate these risks, Rhetorical Hospital must enforce the following security controls: Technical Controls: Disable <i>AutoPlay/AutoRun</i> features across all hospital workstations via Group Policy to prevent automatic code execution. Implement Endpoint Detection and Response (EDR) to block unauthorized peripheral devices. Operational Controls: Mandate routine automated antivirus and anti-malware scans for any external storage device attempting to connect to the hospital network. Managerial Controls: Conduct regular <i>Security Awareness Training</i> so employees know to turn found devices over to IT rather than plugging them in. Enforce an <i>Acceptable Use Policy (AUP)</i> that strictly forbids